



Compliance Handbook

Version No.	V1.0	Release date	24 Apr 2023
Details	Name & Job Role	Signature	Date
Prepared by	Rathish M / Dinesh Kumar Assistant Manager – Compliance / Compliance Lead		08 Feb 2023
Reviewed by	Dheeraj K J Senior Compliance Manager Mervin S Head - IT Infra & CISO		27 Mar 2023
Approved by	Kathy Theophilus – Head of Data Operations		24 Apr 2023
File name & Location	Merit Compliance Handbook – v1.0 24Apr2023_(INT)		

CHANGE HISTORY

Author	Approved By	Change Description	Ver No.	Release Date
Rathish M / Dinesh Kumar	Kathy Theophilus	First version	V1.0	24 Apr 2023

1. Scope

The purpose of this document is to provide an overview of the various general compliance requirements for the new joiners at Merit.

2. Overview

2.1 Information Security:

2.1.1 Policies and procedures:

Policies and procedures relating to information security are available in mKconnect (the intranet portal <http://mkconnect.meritgroup.com/>).

This includes the Information Security Policy, Information Security Objectives, ISMS awareness content.

There could be further policies and procedures that should to be adhered to, based on the team, project and location.

The employees are advised to go through the policies and procedures available in mKconnect and abide by the same. In case of any doubts or queries the employee can connect with their reporting manager or the Compliance team.

2.1.2 Handling personal data:

As Merit processes personal data of European and UK citizens, GDPR (General Data Protection Regulation) will apply. The European version of GDPR is called EU GDPR and the UK version is known as UK GDPR.

GDPR requires that personal data is handled in a secure way. Every employee should ensure that all the personal data security practices - required by the organisation and specific to the team - are followed accordingly.

In client facing projects, Merit is a Data Processor (an entity that processes personal data on behalf of a controller). Merits' clients/customers are usually the Data controller (the entity that defines the purpose and means of processing personal data)

Personal data transfer, processing, storage, retention and disposal period and method of handling personal data are agreed with clients either by way of an MSA (Master Service Agreement), SOW (Statement of Work) or SOP (Standard Operating Procedure)

Every team will maintain a DPIA (Data Protection Impact Assessment) as a part of risk register. The DPIA aims to identify and evaluate privacy impact on individuals due to various business practices. Based on the risk value, the privacy risk owner will have to take appropriate steps to treat the risks

2.1.3 Data Subject Requests:

Individuals in the UK and European Union have several rights relating to the processing of their personal data. These rights include:

1. The Right to be Informed
2. The Right of Access
3. The Right to Rectification
4. The Right to Erasure or Restrict Processing
5. The Right not to be subject to Automated Decision-Making

When a person (Data subject) exercises their right by sending an email or an online request asking for any of the above, it is called a Data subject request. These requests are usually sent to the DPO (Data Protection Officer), but they may also reach anyone at Merit. Therefore, it is essential to recognize the subject access request and forward it to the DPO (dpo.merit@meritgroup.co.uk) for further action. Some of the projects at Merit have internal processes and procedures to handle Data subject requests, which means that these requests need to be handled by the team and need not be forwarded to the DPO.

2.1.4 Access controls:

The access control systems at Merit are designed to ensure that only authorized individuals are able to access the company's systems and physical spaces. All employees are expected to adhere to the access control restrictions in place for different systems and processes.

Physical access controls have been implemented throughout the Merit premises to ensure that only authorized individuals are able to access specific areas. Access controlled doors are located throughout the building, and employees are expected to use their access cards diligently. Each employee should use their own access card at all access points where they are allowed. It is important that employees do not share their access cards with others and that they do not tailgate.

System and application access controls are managed by using individual credentials for NT login, firewall, internal project tools, client-provided tools, online websites, and other relevant resources. In cases where a shared NT login is used, a sharing matrix tracker needs to be maintained by the process owner to capture information about the users who have access to the shared login.

The process owner is responsible for ensuring that periodic access reviews are conducted for internal project tools used by the team. Additionally, for client or externally provided applications, tools, or websites, the client needs to be made aware of employee exits as applicable.

Overall, the access control measures at Merit are designed to protect the company's systems and physical spaces from unauthorized access. It is the responsibility of all employees to follow these guidelines and restrictions to ensure the security of the company's assets.

2.1.5 Password security:

Regardless of the circumstances, passwords must never be shared or revealed to anyone else besides the authorised user. To do so, exposes the authorised user to responsibility for the actions that the other party takes with the password.

The user should bear in mind the below three points when creating and using the password:

1. All passwords must have minimum of eight (8) characters in length and for system administrator passwords must have minimum of Twenty-five (25) characters in length.
2. The password should be alphanumeric containing a minimum of one (1) numeral and one (1) special character
3. All passwords will expire every 90 Days either from the date of creation or date of reset

The above three points are not applicable for SFTP, G-Suite for Business and password protected email attachments

2.1.6. File Naming Conventions and Document Classification:

All files/documents/records/templates created at Merit should follow a file naming convention. The file name is to mainly identify the type or security level required for the document and also to maintain a standard across various files created/updated at Merit.

Internal documents/records (created within Merit and shared with Merit stakeholders)

<Merit>
<Department Name or Team name>
<mPrime Project name >
<Document or Template Type>
<Version Number>
<Date of Creation>
<Document classification type>

Example:

Merit_Airbusiness Subscription_ Chat Support_SOP_v1.0_DDMmmYYYY_(RSP)

Merit_Tactical Data_Training manual_v1.0_DDMmmYYYY_(RSP)

External documents (created within Merit and shared with stakeholders outside of Merit)

<Merit>
<Client name>
<mPrime Project name>
<Document or Template Type>
<Version Number>
<Date of Creation>
<Document classification type>

Example:

Merit_Air Business Subscriptions_ Chat Support_SOW_v1.0_DDMmmYYYY_(CONF)

Merit_Glenigan Limited_ G2 Development_ SOW_v1.0_DDMmmYYYY_(CONF)

The Document Classification type at Merit are based on the below 5 types:

1. Public (P)
2. Internal (INT)
3. Restricted and Specific (RSP)
4. Restricted and Internal (RINT)
5. Confidential (CONF)

Public (P)

If the information is leaked outside the organisation, it is most likely to have nil or negligible effect on the business process, financial loss or business reputation. Examples include marketing brochures, press releases, information on the organisation's web-sites.

Internal (INT)

If this information is leaked outside the organisation, it will result in minimal effect on the business process, financial loss and/or business reputation. Disclosure of this information will most likely not cause serious harm to the organisation, business process. Access of this information is provided to all internal users depending on their roles. Examples include circulars, company policies, company guidelines, etc.

Restricted

If this information is leaked outside the organisation, it will result in moderate effect on the business process, financial loss and/or business reputation, depending on the type of information being disclosed and level of access provided to the users.

So, there can be two types of sub classification applicable to the under restricted category depending on the type of information available within the respective information asset.

Restricted Specific (RSP)

Restricted specific information is set of information for which the access is restricted to a particular set of teams within the company; this type of information is usually shared to a particular set of teams with the organisation or a group of team members within the specific team. Examples include Billing reports, Internal Monthly performance report, SOP, Risk Register, Monthly performance tracker, Final upload file, etc.

Restricted Internal (RINT)

Restricted Internal information are set of information for which the access is restricted only to team members within the specific team or to the clients for which the team is specifically working for; this type of information is shared only within the team members of specific team. Examples include Training Manual, Reports shared with specific client, Daily Performance trackers, etc.

Confidential (CONF)

If this information is leaked outside the organisation, it will result in significant effect on the business process, financial loss and/or business reputation. Compromise of this information may likely result in statutory, legal non-compliance. Access to this information must be restricted based on the concept of need-to-know. Disclosure requires the information owner's approval. In case information needs to be disclosed to third parties a signed confidentiality agreement is required. Examples include customer contracts, rate cards, statement of work, employee database, new product development & project plans, revenue tracker, etc.

2.1.7 Incident reporting:

All information security incidents need to be reported to the below email address:

incident.management@meritgroup.co.uk

The incident management team will review the reported incident and take the necessary action.

An information security incident is defined as any event that has resulted or could result in:

1. The disclosure of confidential information to any unauthorized person
2. The integrity of the information being put at risk
3. The availability of the system or information being put at risk

An adverse impact e.g.

1. Loss of reputation
2. Legal obligation or penalty
3. Financial Loss
4. Disruption of Merit's process/activities

Any data breach pertaining to personal data that is reported to incident management team will be in-turn reported and escalated to the data controller or data protection authority (ICO) without undue delay within 12hrs

2.2 Quality Management System:

2.2.1 Policies and procedures:

Policies and objectives relating to Quality Management System are available in mKconnect (the intranet portal <http://mkconnect.meritgroup.com/>).

An overview of the Quality Management System is provided to the new joiners and further training will be provided during the course of employment.

The employees are advised to go through the policies and procedures available in mKconnect and abide by the same. In case of any doubts or queries the employee can connect with their reporting manager or the Compliance team to address any questions or concerns

2.2.2 Team target reporting:

All the teams at Merit will have to report their monthly performance to the compliance team. The team's performance metrics will be divided into five broad categories:

1. Productivity
2. Quality
3. TAT (Turnaround Time)
4. ISMS (Information Security Management System)
5. Customer Complaint

The adherence level will be checked for two types of targets: External target and internal target. The external targets are the targets/deliverables agreed with the client. The internal targets are set internally by the team.

For example: If a team has agreed to deliver 100 records per month to the client, then the 'External target' for the team for 'Records per month' is 100. And internally the team can set itself a target of 120 for 'Records per month' as 'Internal target'. Ensure that the internal target is always qualitatively higher or equal to the external target and is never lower.

If an external target is missed, the team will have to document the root cause, correction and corrective action in the standard excel template. Also if the miss is due to any client dependency, the team will have to provide justification along with the necessary evidences.

If the client dependency is established, the team will still be reported to have not met the target; however, the team will be marked under, 'target miss due to client dependency'

2.2.3 RCA, Correction and Corrective action:

The process owner has to document an RCA, Correction and Corrective action in the following scenarios:

1. Client issue / escalation
2. Non-conformity in the internal/external audit
3. OFI / Opportunity for improvements identified in internal audit (Corrective action is required)
4. Team not achieved a KPI/target agreed in the contract / SoW
5. Information security incident

RCA refers to Root Cause Analysis. This is the first step to identify what is causing the problem or issue. The 5 Why's Analysis is a popular RCA technique, which means to keep asking Why until the root cause of the issue is identified. For example, if a team missed productivity target missed for this month. The 5 Why analysis will look like one below:

1. Why was the productivity target missed?

Answer: Because the productivity target for the month is very high

2. Why was the productivity target for the month very high?

Answer: The client provides the target in the beginning of the month and this time the target set was high

3. Why did the manager agree to this high target, when it is clearly known that the target won't be met?

Answer: The manager had trained additional buffer resources who could be used under these circumstances

4. Why hasn't the manager used the additional buffer resource to meet the target?

Answer: The manager used the buffer resources, but their performance was not up to the mark to meet the targets.

5. Why were the buffer resources not performing well?

Answer: Because periodic refresher training was not conducted for the buffer resources

In the given situation, the root cause has been identified as insufficient refresher training, which resulted in not achieving the productivity target. During the 5 Why analysis, there is no need to limit the number of questions to five, and one can continue until the underlying cause is determined.

Correction is something that we do to fix a problem, it is a temporary measure to fix an issue and stop further damage. For the same example of a team missing the productivity target, the correction could be compensating the client by delivering more records in the upcoming month etc.

Corrective action is done once the root cause is identified. An action taken to remove or address the root cause of the issue and ensure that it does not happen again in future is known as Corrective action. In the example of team missing productivity target, corrective action would be to ensure periodic refresher training is provided to the buffer resources. Here, note that the corrective action directly addresses the cause and prevents recurrence of the issue due to same cause.

Corrective actions are continuous process and needs to be monitored and tracked for its effectiveness. For example, if the team creates an Excel tracker to ensure buffer resources are provided with quarterly refresher trainings; the process owner or Manager will need to take the responsibility to review the tracker periodically to ensure its effectiveness.

2.2.4 Risk Assessment:

Risk assessment is carried out to understand and document the risks relating to Quality, Privacy and Information Security. Every team/project maintains a risk register where risks are identified, evaluated and controlled using suitable risk treatment techniques.

2.2.5 Feedback Tracker:

Feedback tracker is used to capture the different negative and positive feedback obtained from the client for every project. It is available as a part of m-Prime which can be accessed from the below location:

<http://mprime.meritgroup.com/IssueTracker>

The tracker is very elaborate and helps in documenting several fields relating to a feedback. It captures the feedback provider name, feedback date, response date, feedback severity level, root cause owner, description of root cause, correction, corrective action, planned and actual closure dates, division head, project owner and closure mode.

The mPrime feedback tracker is accessible to the process owner and can be made accessible to other stakeholders at the team if required.

2.2.6 ISO folder:

ISO folder is a folder used by the teams to maintain all the compliance related documents and records for the team/project.

The folder can be accessed by authorized personnel in the following pathway:

[\\ch1012vva](#)

Under the parent folder mentioned above there are sub folders created after the team/project name. The team manager/TL/Process owner will need to get access to their specific teams ISO folder by raising a ticket to the IT Infra team

Inside every team folder, there will be three subfolders named: Documents, Records, Templates

i) Documents to be made available in the documents folder:

- SOP
- SOW
- Process flow and Data flow diagrams
- Training manual and Training plan
- Roles and responsibility document
- All other process-related documents

ii) Records to be made available in the records folder

- Performance reports on productivity, quality and TAT
- Minutes of Meetings
- NC trackers
- Training tracker and assessment records
- Sharing Matrix
- Skill Matrix
- Corrective action files
- KT documents and sign off
- All other records required to substantiate conformance to SOP and SOW

iii) Templates of reports and trackers currently used within the respective team

The documents, records and template folder will be verified for accuracy/ integrity, completeness, file naming convention and adherence to retention schedules.

2.2.7 Internal audit:

Internal audits are conducted to verify conformity against requirements for the below three international standards:

1. ISO 9001:2015 (QMS / Quality Management System)
2. BS 10012:2017 (PIMS / Personal Information Management System)
3. ISO 27001:2013 (ISMS / Information Security Management Standard)

All operations, support and IT Software teams will undergo an internal audit twice in a year. The frequency and the list of teams to be audited may however vary based on the scope of the audit.

The duration of the audit could be anywhere from 1.5 Hrs to 15 Hrs and is based on the team size, revenue and business priority.

The audit will be planned, scheduled and conducted by an internal auditor who is either from the compliance team or an internally certified auditor who are trained to conduct audits.

During the audit the auditors will look for adherence to standard requirements, requirements agreed with the client in the SoW and internal requirements mentioned in SoP. The auditors may pick samples to verify conformity towards these requirements.

Following the audit, the auditor will publish a report to the auditee and management on the non-conformities (NC) and opportunity for improvement identified during the audit. The NCs will be categorised and presented based on their severity levels. A severity rating of 1 means, very high severity and 5 refers to low severity.

2.2.8 Spot audit:

Spot audits are currently conducted for the Operations and Support teams. All the teams will undergo a spot audit at least once in a year.

Teams will be selected randomly and will be audited within a very short notice period. The audit will be done for 1 Hour and will revolve around verification, recent projects/records completed, information security practices, reporting, folder access and team's awareness on different standards.

The process owner will have to ensure that the team members are made available during the spot audit.

Once the spot audit is completed the auditor will share the spot audit observations through email entailing the critical and non-critical observations.

The auditee will have to ensure that the observations made during the audit are reviewed and addressed as these will be verified during the next internal audit cycle.

2.2.9 M-App Quiz:

M-App is an internal portal used to conduct quizzes for the employees and tracks the scores of the same. Compliance team will run M-App quiz on topics such as Information Security, Privacy, GDPR and Quality.

The quiz will automatically pop-up when the employee opens Timelogger. The content for the quiz will be displayed first, based on which the quiz is set. There will be three questions and the employee will need to provide minimum 2 correct answers to pass the quiz. In case, the employee

fails the quiz, the quiz will reappear every alternate day until the employee provides the correct answer.

The results of the quiz can be viewed by the project manager in Wisebuddy.

Employees are encouraged to take the quiz whenever it appears in Timelogger. If an employee chooses to skip the quiz once, they may answer it during their next login. However, if an employee has already used the skip option and tries to login again, they will be required to complete the quiz before they can access the time logger again. Failure to complete the quiz will result in the time logger being locked, and it can only be unlocked by completing the quiz.

2.2.10. Awareness Campaigns:

Merit conducts an organisation wide full month awareness campaign every year focusing on improving employee awareness on topics such as Quality, GDPR & Information security.

The campaign will consist of trainings, daily posters and several contests such as puzzles and quizzes relating to the theme (Quality / Information security) to promote employee engagement.

Employees who participate and win various contests are recognized through Laurels, which is our employee recognition platform. Additionally, we also make announcements through email and mKconnect to celebrate their achievements.